

Clase 322 — Threat intelligence operacional avanzada

Parte: **17 — Profundización para certificaciones** · Fuente: *Blue Team Level 1 (BTL1) — Threat Intelligence · CompTIA CySA+ (CS0-003) · SANS FOR578* 🕒 Duración estimada: **140 min** · Nivel: **Avanzado**

Objetivo

Transformar datos sueltos de amenazas en **inteligencia accionable** que dirija la defensa. Esta clase cubre el **ciclo de inteligencia**, la diferencia entre **IOCs e IOAs**, la **Pyramid of Pain**, el consumo y producción de **feeds** mediante una **TIP** (Threat Intelligence Platform) como **MISP**, el mapeo a **MITRE ATT&CK** y la aplicación del **Diamond Model** para caracterizar intrusiones. Es contenido puramente **defensivo**: entender al adversario para detectarlo y anticiparlo, no para imitarlo.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

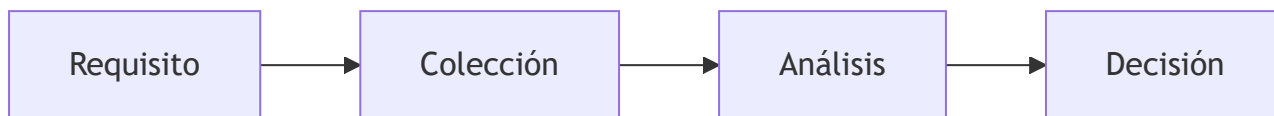
1. **Ejecutar** las seis fases del ciclo de inteligencia sobre un caso real.
2. **Diferenciar** IOCs de IOAs y ubicar cada indicador en la Pyramid of Pain para priorizar defensas.
3. **Operar** MISP: crear un evento, añadir atributos, etiquetar con taxonomías y compartir en comunidad.
4. **Mapear** la actividad de un adversario a técnicas de MITRE ATT&CK y construir una matriz de cobertura.
5. **Aplicar** el Diamond Model para caracterizar una intrusión (adversario, capacidad, infraestructura, víctima).

Temas

#	Tema	Por qué importa
1	Ciclo de inteligencia (6 fases)	Convierte datos en decisiones, no en ruido
2	Niveles: estratégico, operacional, táctico	Cada audiencia consume distinta inteligencia
3	IOC vs IOA	Distinguir "qué se vio" de "qué se está haciendo"
4	Pyramid of Pain	Prioriza indicadores que más cuestan al adversario
5	Feeds, TIP y estándares (STIX/TAXII)	Automatiza ingesta y compartición
6	MISP en operación	Plataforma abierta para gestionar y compartir IOCs
7	MITRE ATT&CK y mapeo	Lenguaje común de TTPs y cobertura defensiva
8	Diamond Model	Estructura para caracterizar y correlacionar intrusiones

Modelo mental y caso de decisión

Inteligencia reduce incertidumbre para una decisión; indicadores caducan y las hipótesis deben competir.



Caso razonado. Diez fuentes copian el mismo IOC. Se cuenta una raíz y se calibra confianza.

Glosario operativo complementario

Término	Definición
Evidencia	Información cuya procedencia y relación con un criterio pueden revisarse.
Supuesto	Condición declarada de la que depende una conclusión.
Riesgo residual	Exposición que permanece después del tratamiento.

Criterio de dominio

El alumno demuestra dominio cuando explica el diagrama, resuelve el caso con evidencia, declara límites y puede defender por qué su decisión cambia si cambia un supuesto.

Definiciones y características

- **Ciclo de inteligencia:** proceso de **Dirección** → **Recolección** → **Procesamiento** → **Análisis** → **Difusión** → **Retroalimentación**. Característica clave: es iterativo; sin *dirección* (requisitos) se recolecta ruido.
- **IOC (Indicator of Compromise):** evidencia observable de que algo ya ocurrió —hash, IP, dominio, mutex. Característica clave: es reactivo y volátil; el adversario lo cambia con facilidad.
- **IOA (Indicator of Attack):** comportamiento en curso que revela intención —p. ej. proceso de Office lanzando PowerShell codificado. Característica clave: es proactivo y más difícil de evadir porque describe *cómo* actúa el atacante.
- **Pyramid of Pain (David Bianco):** jerarquía de indicadores por el "dolor" que causa al adversario detectarlos: hash < IP < dominio < artefactos de red/host < herramientas < **TTPs**. Característica clave: cuanto más arriba, más caro le resulta al atacante adaptarse.
- **TIP (Threat Intelligence Platform):** sistema que ingiere, normaliza, enriquece y comparte inteligencia (p. ej. **MISP**, OpenCTI). Característica clave: automatiza el flujo de feeds hacia los controles (SIEM, EDR, firewall).
- **STIX / TAXII:** **STIX** es el formato estructurado para describir amenazas; **TAXII** es el protocolo para transportarlo. Característica clave: permiten compartir inteligencia entre organizaciones de forma legible por máquina.
- **MITRE ATT&CK:** base de conocimiento de tácticas (el *por qué*) y técnicas (el *cómo*) del adversario, con IDs (TA0001 , T1059). Característica clave: es el lenguaje estándar para mapear TTPs y medir cobertura de detección.

- **Diamond Model:** modelo que relaciona cuatro vértices —**adversario, capacidad, infraestructura, víctima**— de un evento de intrusión. Característica clave: pivotar por un vértice descubre eventos relacionados y campañas.

Herramientas y preparación

Entorno **de laboratorio propio y aislado**; solo se consume inteligencia pública o ficticia:

- **MISP** (máquina virtual o contenedor oficial) para gestionar eventos, atributos y feeds.
- **MITRE ATT&CK Navigator** para construir capas (layers) de cobertura y superponer grupos.
- **Fuentes abiertas** de ejemplo: feeds públicos de MISP, CISA Advisories, informes de proveedores (solo lectura para el ejercicio).
- **Hoja de cálculo** para el mapeo TTP ↔ detección ↔ fuente de log.
- **Editor de texto / JSON** para inspeccionar objetos STIX de ejemplo.

Nota ética: se trabaja con inteligencia **defensiva**. No se opera infraestructura de adversarios ni se ejecuta malware; los IOCs se usan para detectar, no para atacar.

Laboratorio guiado — Construir un playbook de threat intelligence

Ejercicio aplicado: a partir de un informe público de un grupo (ficticio o de ejemplo), produces un playbook de TI completo.

1. **Define los requisitos (Dirección).** Escribe la pregunta de inteligencia: p. ej. "¿Está mi organización expuesta a las técnicas del grupo APT-X que ataca al sector financiero?". Sin esto, todo lo demás es ruido.
2. **Recolecta.** Reúne el informe/CTI de ejemplo y extrae indicadores y comportamientos. Separa lo observable (IOCs) de los comportamientos (IOAs).
3. **Procesa en MISP.** Crea un evento, añade atributos (dominios, hashes, IPs de ejemplo), etiqueta con taxonomías (`tlp:amber` , `kill-chain`) y galaxias (grupo/ATT&CK).
4. **Analiza con la Pyramid of Pain.** Clasifica cada indicador por nivel y decide dónde invertir: bloquear hashes es barato para el atacante; detectar TTPs le duele. Prioriza detecciones de comportamiento.
5. **Mapea a MITRE ATT&CK.** Lista las técnicas observadas (p. ej. `T1566` phishing, `T1059.001` PowerShell, `T1486` cifrado). Construye una capa en ATT&CK Navigator.
6. **Cruza con tu telemetría.** Para cada técnica, anota qué fuente de log/regla la detectaría (EDR, Sysmon, proxy). Marca huecos de cobertura.
7. **Aplica el Diamond Model.** Rellena los cuatro vértices del evento: adversario (APT-X), capacidad (malware/herramientas), infraestructura (C2/dominios), víctima (sector/activo). Anota relaciones para pivotar.
8. **Difunde.** Redacta tres productos: uno **táctico** (lista de IOCs/detecciones para el SOC), uno **operacional** (TTPs y campaña para IR) y uno **estratégico** (riesgo del sector para dirección).
9. **Retroalimenta.** Registra qué detecciones se crearon, cuáles fallaron y qué nueva pregunta de inteligencia surge, cerrando el ciclo.

Entregable: evento MISP etiquetado, capa de ATT&CK Navigator, matriz TTP↔detección, diagrama Diamond y los tres productos de inteligencia por nivel.

Ejercicios

1. Clasifica diez indicadores dados como IOC o IOA y justifica cada uno.
2. Ubica cinco indicadores en la Pyramid of Pain y explica la prioridad de defensa resultante.
3. Crea un evento MISP con al menos cinco atributos, dos etiquetas de taxonomía y una galaxia de ATT&CK.
4. Mapea un informe de amenazas a seis técnicas de ATT&CK y construye la capa en Navigator.
5. Rellena un Diamond Model para una intrusión de ejemplo y describe un pivote posible por infraestructura.
6. Redacta un producto de inteligencia estratégico (media página) para la dirección a partir de un informe táctico.

Reto verificable

Reto: entrega un playbook de threat intelligence que convierta un informe de amenazas en detecciones y en productos para tres audiencias.

Criterio de aceptación:

- El playbook parte de un **requisito de inteligencia** explícito (fase de Dirección).
- Los indicadores están **separados en IOCs e IOAs** y clasificados en la Pyramid of Pain con prioridad justificada.
- Existe un **evento MISP** con atributos, taxonomías (TLP) y galaxia de ATT&CK.
- Hay una **capa de MITRE ATT&CK** con al menos seis técnicas y su fuente de detección, señalando huecos de cobertura.
- Se incluye un **Diamond Model** con los cuatro vértices y un pivote propuesto, más tres productos de inteligencia (táctico, operacional, estratégico).

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Tengo miles de IOCs y ninguno sirve"	Recolectaste sin dirección. Empieza por el requisito de inteligencia y filtra lo relevante.
"Bloquee los hashes y el ataque volvió"	Los hashes están en la base de la pirámide; el atacante los cambia. Sube a detectar TTPs.
"MISP está lleno pero nadie lo usa"	Falta integración y contexto. Etiqueta con TLP/ATT&CK y expórtalo al SIEM/EDR.
"Mapeé todo a ATT&CK pero sin telemetría"	Mapear sin cruzar con logs no mide cobertura. Asocia cada técnica a una fuente de detección.
"Confundo táctica y técnica"	Táctica = objetivo (por qué); técnica = método (cómo). Usa los IDs TA / T para no mezclarlos.
"Mi informe estratégico está lleno de hashes"	Erraste la audiencia. La dirección necesita riesgo y tendencia, no indicadores crudos.

? Preguntas frecuentes

? **¿Cuál es la diferencia práctica entre IOC e IOA?** Un IOC dice "vi esta IP/hash" (pasado, fácil de cambiar); un IOA dice "estoy viendo a Word lanzar PowerShell codificado" (comportamiento, difícil de evadir). Las detecciones basadas en IOA envejecen mejor.

? **¿Por qué la Pyramid of Pain cambia mi estrategia?** Porque revela dónde invertir: bloquear indicadores de la base es barato de evadir para el adversario; detectar sus TTPs (la cima) le obliga a rediseñar su operación. La defensa madura sube por la pirámide.

? **¿MISP u OpenCTI?** MISP destaca en compartición de indicadores y comunidades; OpenCTI en modelado de conocimiento y relaciones. Muchas organizaciones usan MISP para IOCs y ATT&CK/STIX como capa de conocimiento; no son excluyentes.

? **¿El Diamond Model reemplaza a la Cyber Kill Chain?** No, se complementan. La Kill Chain describe las fases de un ataque en el tiempo; el Diamond Model caracteriza cada evento y permite pivotar entre eventos relacionados de una campaña.

Referencias

- Security Blue Team. *Blue Team Level 1 (BTL1)* — dominio *Threat Intelligence*.
- Bianco, David. *The Pyramid of Pain* — detect-respond.blogspot.com.
- MITRE. *ATT&CK* — attack.mitre.org · *ATT&CK Navigator*.
- Caltagirone, Pendergast & Betz. *The Diamond Model of Intrusion Analysis* — activeresponse.org.
- MISP Project. *MISP User Guide* — misp-project.org · OASIS STIX/TAXII.

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 321 — Comunicación y reporte para analistas de seguridad](#)

Siguiente clase

[Clase 323 — Pruebas de seguridad del software y evaluación](#)